

PraisonAI vulnerable to unauthenticated arbitrary file read via MCP workflow.show, workflow.validate, deploy.validate

Report Type: Weekly · Generated: May 31, 2026 16:17 UTC · Coverage: May 29 – May 31, 2026

1	0	1	0
Total Advisories	Critical	High	Medium

Executive Summary

Summary The fix for GHSA-9mqq-jqxf-grvw / CVE-2026-44336 is incomplete. The original advisory description named four vulnerable handlers in ``mcp_server/adapters/cli_tools.py``: `>` "registers four file-handling tools by default, ``praisonai.rules.create``, ``praisonai.rules.show``, ``praisonai.rules.delete``, **and ``praisonai.workflow.show``". Each accepts a path or filename string from MCP ``tools/call`` arguments... **with no containment check**." Commit ``68cc9427`` ("fix(security): harden MCP rules path handling...") added a ``_resolve_rule_path()`` helper and applied it to ``rules.create``, ``rules.show``, and ``rules.delete``. ``workflow.show`` was left unchanged. Two adjacent handlers in the same file have the same pattern, ``workflow.validate`` and ``deploy.validate``. Neither was mentioned in the original advisory. Both remain unchanged. The original advisory also identified the dispatcher (``server.py:281-298``) as a root cause. It accepts unvalidated ``**kwargs`` from ``params["arguments"]`` with no enfo

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
PraisonAI vulnerable to unauthenticated arbitrary file read via MCP workflow.show, workflow.validate, deploy.validate.	Critical	9.8	—	## Summary The fix for GHSA-9mqq-jqxf-grvw / CVE-2026-44336 is incoming.

MITRE ATT&CK;® Coverage

ATT&CK; technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Advisory Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	—

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for PraisonAI vulnerable to unauthenticated arbitrary file read via MCP workflow.show, workflow.validate, deploy.validate.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK; techniques.

Appendix — Report Metadata & Legal

Field	Value
Report ID	intel--0d772ee3e00c5b0f9a5177ad
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v143.0.0 GOD-MODE
Generated At	2026-05-31T16:17:22.878214+00:00
Customer Tier	PRO
Customer Email	—
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries contact bivash@cyberdudebivash.com.